

Relatório Técnico de Análise de Malware

Sumário

1. Apresentação
2. Resumo Executivo
3. Montagem do Laboratório e Ferramentas utilizadas
4. Identificação da ameaça
5. Vetores de Infecção
6. Resultados da análise
    a. Análise estática
    b. Análise dinâmica
7. Mapeamento do MITRE ATT&CK
8. Impacto potencial
9. Medidas de mitigação
10. Conclusão
11. Referências

1. Apresentação

Malware Investigado: Win64.NukeSped

Data: 07/09/2025

Analista Responsável: Mauricio Robert

Organização: Faculdade Impacta

2. Resumo Executivo

O Win64. NukeSped é um malware ligado ao grupo Lazarus, da Coreia do Norte, que atua como backdoor, permitindo acesso remoto a sistemas. Isso possibilita atividades como espionagem, roubo de dados e controle completo das máquinas comprometidas. Ele foi empregado em ataques notórios, como a invasão a cassinos em Macau e a exploração de vulnerabilidades no Adobe Flash Player, que funcionaram como porta de entrada para campanhas de espionagem e roubo de dados estratégicos.

3. **Montagem do laboratório e ferramentas utilizadas**

   A análise foi conduzida em um laboratório em uma V.M. isolado e controlado, seguindo as boas práticas de segurança.

   Ferramentas utilizadas:

   ISO: https://archive.org/download/win-10-1803-english-x-64/Win10_1803_English_x64.iso

   Estática: PEStudio, Virus Total e IDA

   Dinâmica: Procmon, Process Explorer, Wire Shark e TCPView

4. **Identificação da ameaça**

- **Nome da Família:** Win64.NukeSped
- **Classificação:** RAT / Backdoor
- **Hash SHA256:** 931f062a629950ad6fb85b83262cc3f730a6e94d43a27b48f7fd857f7722c6ba
- **Origem da Amostra:** Capturada em ambiente controlado : Virtual Machine
- **Data da Captura:** xx/xx/2020

5. **Vetores de infecção**

   Como neste caso estamos estudando-o, baixamos no repositório TheZoo no GitHub.

   Porém em casos reais ele poderia se propagar por meio de:

- **Phishing**: e-mails com anexos maliciosos (documentos do Office, PDFs, executáveis disfarçados) usados para enganar alvos específicos.
- **Exploração de vulnerabilidades**: especialmente em softwares populares como o **Adobe Flash Player,** navegadores, permitindo execução remota de código e por meio da CVE log4shell (CVE-2021-44228).

6. **Resultados da análise**

- **Análise estática**
  Amostra 1 – a880d7c77491fcc6... (64-bit | 181 KB | compilado em 2016)
  Originalidade – Norte Coreano
  Valor de entropy - 6.369
  Virustotal – 53/71
  Flags - WS2_32.dll, PSAPI.dll, WTSAPI32.dll
  CPU – 64 bits

Amostra 2 – 8390e210162d9b14... (32-bit | 169 KB)

Valor de entropy – 6.543

Virustotal – 58/72
Flags - WS2_32.dll, ADVAPI32.dll, USERNV.dll, KERNEL32.dll, SHELL32.dll, WTSAPI32.dll
CPU – 32 bits

Amostra 3 – 6f1c31f5944e46b0... (64-bit | 241 KB)

Valor de entropy - 6.387

Virustotal - 58/72

Flags - WS2_32.dll, ADVAPI32.dll, USERNV.dll, KERNEL32.dll, SHELL32.dll, WTSAPI32.dll

CPU – 64 bits

Conclusão

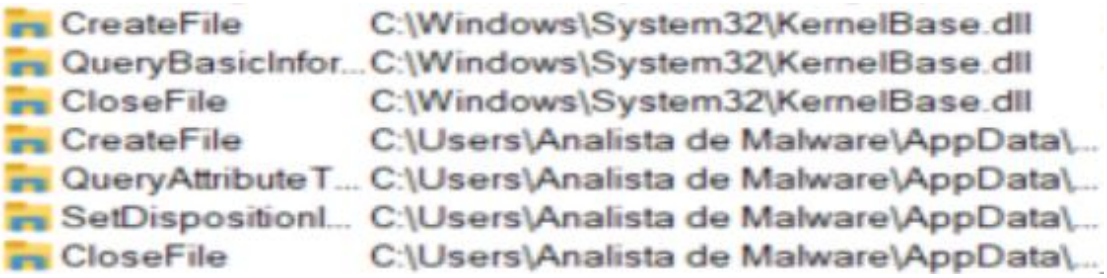
Com base na análise estática:

- Todas as amostras têm **funções de backdoor**: persistência, comunicação C2, injeção de código e espionagem.
- **Diferenças entre elas**:
    - Amostra 1 → mais compacta, possivelmente *loader inicial*.
    - Amostra 2 → foca em espionagem de processos e interação com o usuário.
    - Amostra 3 → versão robusta, com funções de monitoramento e controle completo do sistema.

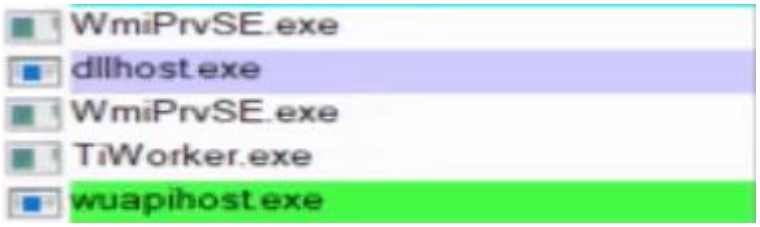
- **Análise Dinâmica**
  Após nossa análise podemos notar alguns processos e criação de arquivos que vamos citar:
  - Ao serem renomeados para extensão .exe, um dos arquivos conseguiu ser executado com sucesso e acabou registrado como um processo legítimo do Windows



- Rundll32.exe -> criou arquivos tempoŕarios depois após isso ja os exclui-o.



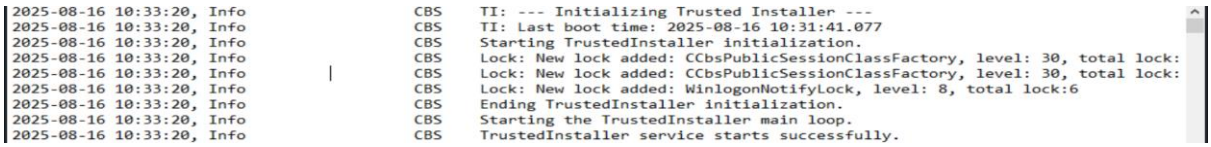
- Wuapihost e WmiPrvSE -> utilizados para updates do windows, porém no caso nossos windows update estava desativado, mostrando possível utilização para mascarar instalação de fora. Um adendo que já foram relatados em outros relatórios do NukeSped.

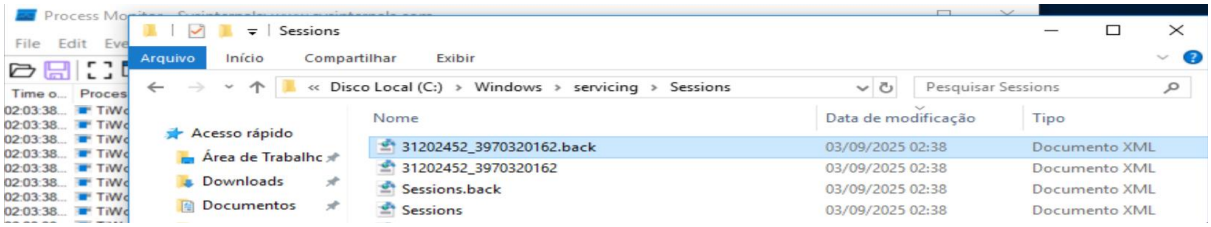


- TiWorker -> injeção de código no TiWorker.exe, processo legítimo do Windows, e o manipula para instalar componentes maliciosos e criar arquivos, usando-o como disfarce para se manter oculto e persistente no sistema.

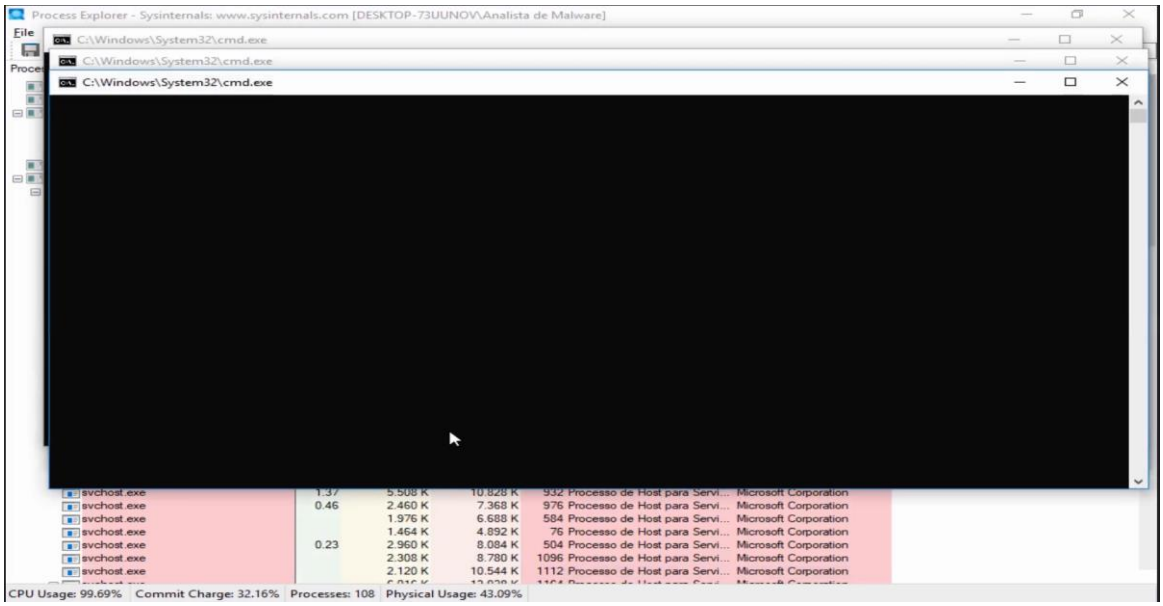


- Ainda falando sobre o abuso do update foram registrados logs de tentativa desses downloads.





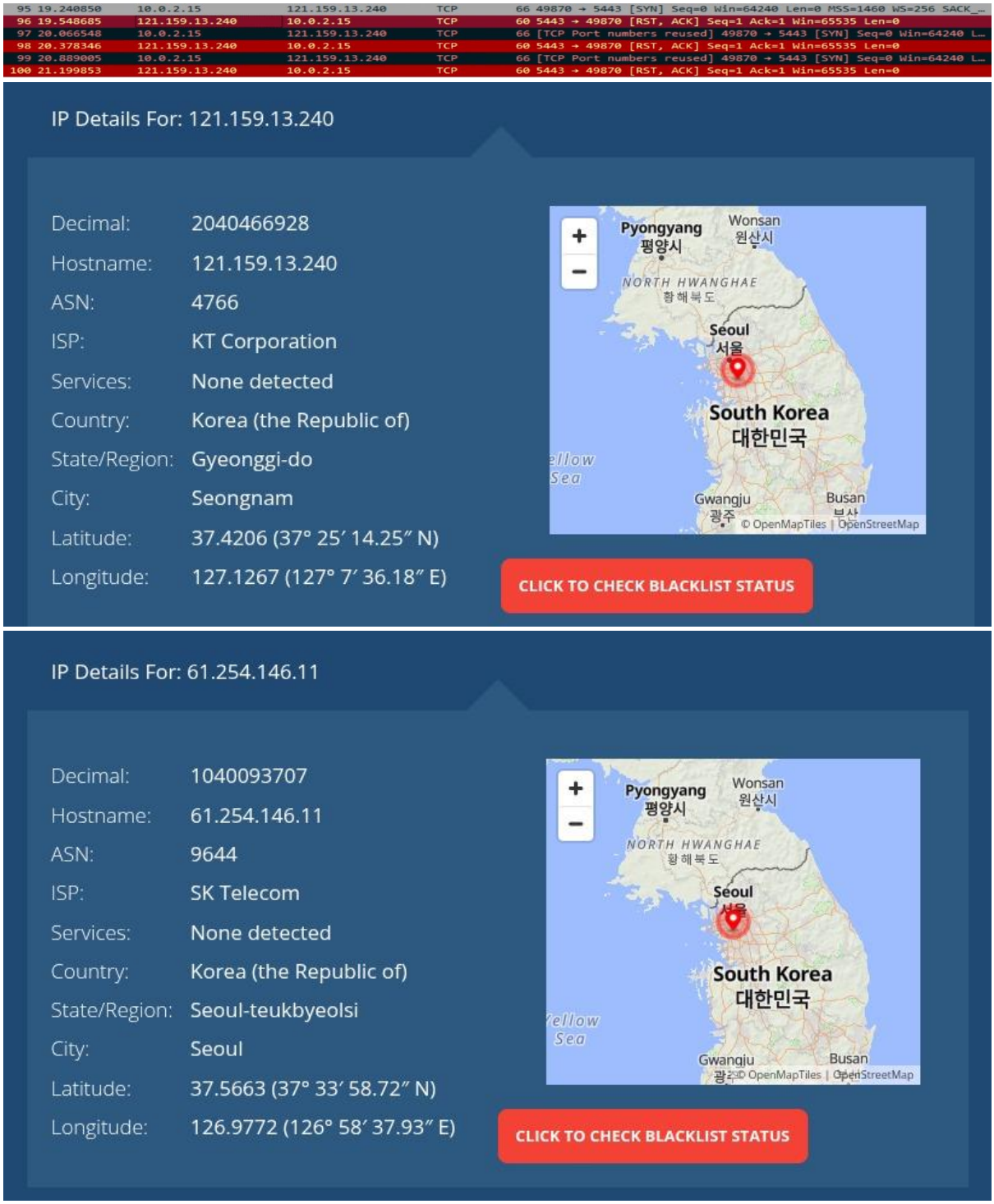
- Foi documentado também após a reinicialização da máquina a abertura de três prompt de comando, mostrando indícios que o malware continuava ativo mesmo após reinicializar a máquina.



  - No TCPView, foi registrada uma conexão em estado FIN_WAIT2, partindo de um IP interno (NAT) para um IP público do Google. O tráfego sugere possível uso de serviços legítimos para camuflar comunicação C2.



  - No Wire Shark foi possível identificar tentativas de conexão com servidores externos e, ao realizar uma busca pelo IP em questão, verificou-se que eles estão associados a alguns sites hospedados na Coreia do Sul.



7. Mapeamento do MITRE ATT&CK

ID	Técnica
T1124	System Information Discovery
T1083	File and Directory Discovery
T1485	Data Destruction (File Deletion)
T1006	Direct Volume Access

T1497	Virtualization/Sandbox Evasion
T1106	Native API Execution
T1105	Ingress Tool Transfer
T1082	System Information Discovery
T1055	Process Injection
T1057	Process Discovery
T1033	System Owner/User Discovery
T1012	Query Registry
T1569	System Services: Service Execution
T1543	Create or Modify System Process
T1134	Access Token Manipulation

8. **Impacto potencial**

   Alguns impactos em potencial que esse malware pode trazer são:

   - Impacto na confidencialidade.
   - Coleta de arquivos, credenciais e informações sensíveis.
   - Monitoramento de processos ou atividades.
   - Manipulação e exclusão de arquivos, assim destruindo evidências ou sabotagem de suas operações.
   - Capacidade de execução de comandos e injeção de códigos.
   - Instalação de serviços de persistência.
   - Criação de chaves de registro.
   - Conexão para servidores de C2, permitindo controle remoto completo do host.

9. **Medidas de mitigação**

   Algumas medidas que podemos seguir são:

   - Bloqueio de anexos suspeitos e filtros de e-mail
   - Consentização e treinamento da equipe
   - Aplicação contínua de patches e atualizações
   - Bloqueio de macros e .exe desconhecidos
   - Monitoramento de processos e de registros
   - Monitoramento do tráfego de rede e bloqueio de conexões suspeitas
   - Revisão de privilégios e autenticação multifatorial
   - Monitoramento de logs e alertas de alterações de arquivos
   - Implantação de firewall e anti-vírus atualizados

10. Conclusão

O **Win64.NukeSped** é um *malware* sofisticado, desenvolvido por grupos de ciberespionagem de alto nível, com foco em **espionagem, persistência e controle remoto** de sistemas críticos. Suas capacidades incluem coleta de informações, execução remota de comandos, injeção em processos legítimos e movimentação lateral dentro de redes corporativas.

Devido à sua complexidade e ao uso de múltiplas técnicas identificadas pelo **MITRE ATT&CK**, o impacto potencial é elevado, podendo comprometer a **confidencialidade, integridade e disponibilidade** dos sistemas infectados.

A mitigação efetiva requer uma abordagem combinada de **prevenção, detecção e resposta.**

11. Referências

- MITRE ATT&CK: https://attack.mitre.org/
- TheZoo Malware Repository: https://github.com/ytisf/theZoo
- VirusTotal: https://www.virustotal.com/
- CVE-2021-44228 (Log4Shell): https://nvd.nist.gov/vuln/detail/CVE-2021-44228
- Trojan Nukesped Flash Player: https://www.pcrisk.pt/guias-de-remocao/9575-nukesped-trojan-mac
- Ataque cassino grupo Lazarus: https://www.welivesecurity.com/br/2018/04/19/killdisk-do-grupo-lazarus-e-o-ataque-a-um-cassino/